

CYBERSECURITY FUNDAMENTALS

A Guide to Cyber Attacks

The Ways of Attacks — a structured walkthrough of how systems, networks, web apps, passwords, and people get compromised.

- 01 Crashing the Gates — Brute Force (DoS / DDoS / SYN Flood)
- 02 The Digital Heist — Shadow & Web Exploits (MitM / SQLi / XSS)
- 03 Hacking the Human — Deception (Phishing Frameworks)
- 04 Cracking the Code — Password Attacks
- 05 The Hacker's Toolkit — Malware & Frameworks

1

Crashing the Gates

Brute Force — overwhelming a system until it can no longer respond

DoS vs. DDoS

A **Denial of Service (DoS)** attack is single-source — think of it as one car deliberately blocking a single-lane road. A **Distributed Denial of Service (DDoS)** attack scales that idea up enormously: the attacker commands an entire **botnet** (potentially millions of compromised computers) to flood a target simultaneously, creating a gridlock so massive that it crashes the server.

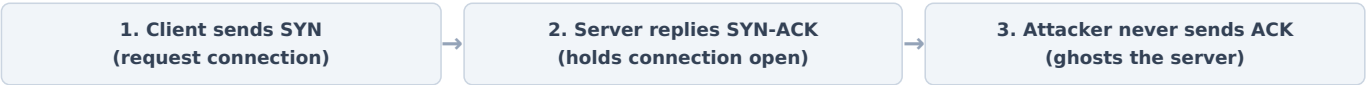
Attribute	DoS	DDoS
Source	Single machine / single attacker	Many machines (a botnet)
Analogy	One car blocking a road	A coordinated, city-wide traffic jam
Scale of impact	Limited by one connection's bandwidth	Can overwhelm even large, well-provisioned servers
Traceability	Easier to trace and block one source	Much harder — traffic arrives from everywhere

NOTE

A botnet is built before the attack even starts — attackers infect ordinary devices (PCs, routers, IoT cameras) with malware that lets them be remotely commanded later, often without their owners ever noticing.

SYN Flood

This attack exploits the normal **TCP three-way handshake** that every network connection relies on to start communication. Instead of completing the handshake politely, the attacker abuses it:



The attacker sends an endless stream of initial SYN requests, then deliberately drops out before completing the link. The server, however, dutifully keeps each **half-open connection** reserved in memory while it waits for a reply that will never come. Repeat this thousands of times per second, and the server's memory and connection tables fill up entirely — leaving no room for legitimate users.

WHY IT WORKS

The vulnerability isn't a bug — it's the protocol's built-in trust that every SYN request is genuine and will be completed. SYN flooding simply weaponizes that trust at scale.

Man-in-the-Middle (MitM)

In a MitM attack, the attacker secretly positions themselves between a user and the server they're communicating with, intercepting traffic in both directions. It's the digital equivalent of a corrupt mail courier who opens, reads, and possibly alters every letter before it reaches its destination — without sender or recipient ever knowing.

REAL-WORLD RISK

This is exactly why doing sensitive transactions (banking, logins, checkout pages) over public Wi-Fi is highly insecure — an attacker on the same network can position themselves to silently intercept your traffic.

SQL Injection (SQLi)

SQLi targets a web application's database through ordinary input fields — search bars, login forms, URL parameters — by sneaking in malicious database commands instead of plain text. If the application doesn't properly sanitize input, the database executes the attacker's logic as if it were a legitimate query.

```
-- Example login bypass logic (illustrative only)
SELECT * FROM users WHERE username = 'admin' AND password = '' OR 1=1 --
```

Because `1=1` always evaluates as true, and `--` comments out the rest of the query, this trick tricks the database's validation logic into granting entry — without ever needing a valid password.

Cross-Site Scripting (XSS) & Session Hijacking

XSS targets visitors of an otherwise legitimate website. The attacker injects malicious script code into a visible, user-controlled element — a comment section, a review field, a profile bio — so that the code runs in the browser of anyone who views that content.

A primary goal of XSS is stealing a victim's **session cookie** — the small piece of data that acts as a temporary authentication pass after login. With that cookie in hand, the attacker can hijack the active session and impersonate the user completely, with no password required.

DEFENSIVE TAKEAWAY

Input sanitization and output encoding on the server side are the core defenses against both SQLi and XSS — never trust raw input from a browser.

Phishing Frameworks

Rather than attacking a machine, phishing attacks the human layer directly. Attackers use convincing visual deception — emails, messages, or fake copycat websites that mimic a trusted brand — to trick people into voluntarily surrendering their own credentials.

Variation	Delivery Method	Defining Trait
Spear Phishing	Email, usually highly personalized	Highly targeted — tailored with specific personal details about the victim
Smishing	SMS text message	Multi-vector traps sent straight to a mobile device
Vishing	Voice phone call	Pure social engineering — no link or screen involved

WHY IT'S EFFECTIVE

All three exploit trust and urgency rather than a technical flaw — which is why awareness and verification habits matter just as much as any technical defense.

Cracking Methodologies

Password cracking has evolved over time, generally trading raw speed for smarter shortcuts:

Brute Force

Trying every possible alphanumeric combination, sequentially, until one works. Slow, but guaranteed to eventually succeed against a short or simple password.

Dictionary Attack

Testing curated lists of common dictionary words and frequently-reused passwords instead of every possible combination — much faster against predictable choices.

Rainbow Tables

Using massive pre-computed tables that map hash values back to their original passwords — effectively a giant cheat sheet that lets an attacker reverse a hashed password almost instantly, with no live computation needed.

Salting Defenses

To defend against rainbow tables, infrastructure databases use **salting**: a unique, random string of data is appended to the password's plaintext *before* it gets hashed.



Because every password now hashes to a completely different value — even if two users chose the identical password — any pre-computed rainbow table becomes useless. The attacker would need to compute a brand new table for every single salt, which is computationally impractical at scale.

TIP

Salting doesn't make a weak password strong — it just neutralizes pre-computed cracking shortcuts. Password length and complexity still matter.

Malware Variations

Virus

Cannot run on its own — it must attach its payload to an active host program and relies on that program being executed in order to replicate.

Worm

Fully independent malware. It self-replicates and spreads from node to node across a network entirely on its own, with no host file or user action required.

Trojan Horse

Masquerades as legitimate, desirable software in order to trick the operator into willingly granting it execution access.

Spyware & Rootkits

Spyware covertly monitors a victim's activity in the background. Rootkits act as a stealth cloak for the rest of the attack — hiding processes, files, and any other system abnormalities from detection.

Type	Needs a Host?	Self-Replicates?	Core Disguise
Virus	Yes	Only via host program	None — relies on attachment
Worm	No	Yes, autonomously	None — relies on network spread
Trojan Horse	No	No	Disguised as legitimate software
Spyware	No	No	Hidden background monitoring
Rootkit	No	No	Hides other malware's presence

Reconnaissance

Before any attack even begins, professional attackers conduct **reconnaissance** — a foundational intelligence-gathering phase where they map out a target's digital footprint, looking for structural cracks: exposed services, outdated software, leaked credentials, or careless employees.

NOTE

Reconnaissance is what ties every previous part of this guide together — an attacker rarely picks a method at random. They scout first, then choose whichever exploit (DDoS, MitM, phishing, password cracking, malware) best matches the weaknesses they've found.

CLOSING SUMMARY

Cyber attacks generally fall into five overlapping categories: overwhelming infrastructure (DoS/DDoS, SYN floods), exploiting web and network trust (MitM, SQLi, XSS), exploiting human trust (phishing), exploiting weak credential hygiene (password cracking), and deploying malicious software (malware) — all of it preceded by reconnaissance to find the path of least resistance.